

Information Security Policy

Document ID: POL-IS-006
Version: 5.0
Effective Date: January 1, 2025
Last Reviewed: December 20, 2024
Approved By: Chief Information Security Officer, Chief Technology Officer
Classification: Internal - Mandatory Compliance

1. Purpose and Scope

1.1 Purpose

This policy establishes the information security framework for Meridian Holdings Group ("the Company") to protect the confidentiality, integrity, and availability of information assets. It defines the minimum security requirements for all systems, networks, and data processing activities.

1.2 Scope

This policy applies to:

- All information assets owned, leased, or managed by the Company
 - All employees, contractors, consultants, and third parties with access to Company information systems
 - All computing devices, networks, applications, and cloud services used for Company business
 - All locations including offices, data centers, and remote work environments
-

2. Information Security Governance

2.1 Organizational Structure

The information security function is structured as follows:

- a) Chief Information Security Officer (CISO): Responsible for the overall information security program, reporting to the CTO and Board Risk Committee
- b) Information Security Team: Responsible for implementing and monitoring security controls
- c) Information Security Committee: Cross-functional committee meeting monthly to review security posture, incidents, and initiatives
- d) Department Security Champions: Designated individuals in each department responsible for promoting security

awareness

2.2 Risk Management Framework

The Company employs a risk-based approach to information security:

- a) Annual comprehensive risk assessment of all critical information assets
 - b) Quarterly review of emerging threats and vulnerabilities
 - c) Risk register maintained by the CISO and reviewed by the Board Risk Committee
 - d) Risk acceptance decisions for residual risks must be documented and approved by the asset owner and CISO
 - e) Framework aligned with ISO 27001 and NIST Cybersecurity Framework
-

3. Access Control

3.1 Access Management Principles

- a) Least Privilege: Users must be granted the minimum level of access necessary to perform their job functions
- b) Need-to-Know: Access to information must be restricted to individuals who require it for legitimate business purposes
- c) Separation of Duties: Critical functions must be divided among different individuals to prevent fraud and errors
- d) Defense in Depth: Multiple layers of security controls must be implemented

3.2 User Account Management

- a) All user accounts must be uniquely assigned to individual users - shared accounts are prohibited
- b) User accounts must be provisioned through the IT Service Desk based on approved access requests
- c) Manager approval is required for all access requests
- d) Access reviews must be conducted quarterly for critical systems and semi-annually for all other systems
- e) Accounts must be disabled within 4 hours of employment termination and within 24 hours of role change
- f) Inactive accounts (no login for 90 days) must be automatically disabled
- g) Privileged accounts (admin, root, service accounts) must be managed through a Privileged Access Management (PAM) system

3.3 Authentication Requirements

System Type	Minimum Requirement
All Company systems	Unique username + password meeting complexity requirements
Systems with sensitive data	Multi-factor authentication (MFA) mandatory
Privileged access	MFA + session recording + just-in-time access
Remote access (VPN)	MFA mandatory

Cloud services	MFA mandatory + SSO where supported
Customer-facing systems	MFA recommended, risk-based authentication

3.4 Password Policy

- a) Minimum length: 14 characters
 - b) Must include characters from at least 3 of: uppercase, lowercase, numbers, special characters
 - c) Password history: Last 12 passwords may not be reused
 - d) Maximum age: 90 days (365 days if MFA is enabled)
 - e) Account lockout after 5 failed consecutive attempts for 30 minutes
 - f) Passwords must not contain the user's name, username, or common dictionary words
 - g) Password managers are recommended and approved tools are provided by IT
-

4. Network Security

4.1 Network Architecture

- a) Networks must be segmented into zones based on security classification
- b) Critical systems must reside in dedicated, highly restricted network segments
- c) DMZ architecture must be implemented for all internet-facing services
- d) Guest Wi-Fi must be completely isolated from the corporate network
- e) Network diagrams must be maintained and updated within 30 days of any change

4.2 Firewalls and Perimeter Security

- a) All network perimeters must be protected by enterprise-grade firewalls
- b) Default deny rules must be implemented - all traffic is blocked unless explicitly permitted
- c) Firewall rules must be reviewed quarterly and unused rules removed
- d) Web Application Firewalls (WAF) must be deployed for all internet-facing web applications
- e) Intrusion Detection/Prevention Systems (IDS/IPS) must be deployed at all network perimeters

4.3 Remote Access

- a) Remote access must be provided through approved VPN solutions only
 - b) Split tunneling is prohibited on Company-managed devices
 - c) Remote access sessions must have a maximum idle timeout of 15 minutes
 - d) All remote access connections must be logged and monitored
 - e) Third-party remote access must be approved in advance and limited in duration
-

5. System Security

5.1 System Hardening

All systems must be hardened according to industry-recognized benchmarks (CIS Benchmarks, DISA STIGs):

- a) Unnecessary services and ports must be disabled
- b) Default accounts must be disabled or renamed with passwords changed
- c) System clocks must be synchronized using NTP to a consistent time source
- d) Administrative interfaces must not be accessible from the internet
- e) Security patches must be applied according to the vulnerability management schedule (Section 5.2)

5.2 Vulnerability Management

- a) Automated vulnerability scanning must be conducted weekly for internet-facing systems and monthly for internal systems
- b) Penetration testing must be conducted annually by qualified external assessors
- c) Critical vulnerabilities (CVSS 9.0+) must be patched or mitigated within 72 hours
- d) High vulnerabilities (CVSS 7.0-8.9) must be patched within 14 days
- e) Medium vulnerabilities (CVSS 4.0-6.9) must be patched within 30 days
- f) Low vulnerabilities (CVSS 0.1-3.9) must be patched within 90 days
- g) Exceptions must be documented with risk acceptance and compensating controls

5.3 Endpoint Security

All Company-managed endpoints must have:

- a) Endpoint Detection and Response (EDR) solution installed and active
- b) Full disk encryption enabled (BitLocker for Windows, FileVault for macOS)
- c) Local firewall enabled
- d) Automatic screen lock after 5 minutes of inactivity
- e) Approved antivirus/anti-malware with real-time scanning enabled
- f) Automatic OS and application updates enabled
- g) USB mass storage devices blocked by default (exceptions require CISO approval)

6. Data Security

6.1 Data Encryption

Data State	Minimum Encryption Standard
Data at rest	AES-256
Data in transit (internal)	TLS 1.2 or higher
Data in transit (external)	TLS 1.3 preferred, TLS 1.2 minimum
Database encryption	Transparent Data Encryption (TDE) or column-level encryption
Backup data	AES-256
Mobile devices	Full device encryption

6.2 Data Loss Prevention

- a) DLP solutions must be deployed for email, web, and endpoint channels
- b) DLP policies must detect and prevent unauthorized transmission of classified information
- c) DLP alerts must be reviewed within 4 hours during business hours
- d) DLP exceptions must be approved by the data owner and CISO

6.3 Backup and Recovery

- a) All critical data must be backed up daily
- b) Backups must follow the 3-2-1 rule: 3 copies, 2 different media types, 1 offsite
- c) Backup integrity must be verified monthly
- d) Full recovery tests must be conducted quarterly
- e) Recovery Time Objective (RTO) for critical systems: 4 hours
- f) Recovery Point Objective (RPO) for critical systems: 1 hour

7. Application Security

7.1 Secure Development Lifecycle

All software development must follow a Secure Development Lifecycle (SDLC):

- a) Security requirements must be defined during the design phase
- b) Threat modeling must be conducted for new applications and significant changes
- c) Secure coding guidelines must be followed (OWASP, SANS)
- d) Code reviews must include security review by a trained developer
- e) Static Application Security Testing (SAST) must be integrated into the CI/CD pipeline
- f) Dynamic Application Security Testing (DAST) must be conducted before each release

- g) Software Composition Analysis (SCA) must be performed to identify vulnerable dependencies

7.2 API Security

- a) All APIs must require authentication
- b) API rate limiting must be implemented to prevent abuse
- c) API keys must be rotated at least annually
- d) API input must be validated and sanitized
- e) API responses must not expose sensitive internal information
- f) API access must be logged and monitored

7.3 Cloud Security

- a) All cloud services must be approved by the Information Security Team before use
- b) Cloud configurations must be reviewed against security baselines (CIS Cloud Benchmarks)
- c) Cloud access must be managed through the Company's identity provider (SSO/SAML)
- d) Data classification must be considered when selecting cloud deployment models
- e) Cloud security posture management (CSPM) tools must be deployed
- f) Cloud service provider agreements must include security requirements aligned with this policy

8. Security Monitoring and Incident Response

8.1 Security Monitoring

- a) Security Information and Event Management (SIEM) must be deployed and monitored 24/7
- b) All security-relevant events must be centrally logged
- c) Log retention: Minimum 1 year online, 7 years archived
- d) Correlation rules must be maintained and tuned to detect known attack patterns
- e) User and Entity Behavior Analytics (UEBA) should be implemented for critical systems

8.2 Incident Response

The Company maintains an Incident Response Plan that defines:

- a) Incident Classification: Severity levels from P1 (Critical) to P4 (Informational)
- b) Response Times:
 - P1: Response within 15 minutes, containment within 1 hour
 - P2: Response within 1 hour, containment within 4 hours
 - P3: Response within 4 hours, containment within 24 hours
 - P4: Response within 24 hours

- c) Incident Response Team: On-call rotation with 24/7 availability
- d) Communication Plan: Notification procedures for management, legal, regulators, and affected parties
- e) Post-Incident Review: Required for all P1 and P2 incidents, completed within 5 business days

8.3 Forensics

- a) Forensic investigation procedures must be documented and followed
 - b) Chain of custody must be maintained for all digital evidence
 - c) Forensic analysis must be conducted by trained personnel or external specialists
 - d) Forensic findings must be documented and retained for potential legal proceedings
-

9. Third-Party Security

9.1 Vendor Security Assessment

All third parties with access to Company systems or data must undergo a security assessment:

- a) Security questionnaire based on industry standards (SIG, CAIQ)
- b) Review of security certifications (ISO 27001, SOC 2 Type II)
- c) Review of penetration test reports (annual)
- d) Assessment of data handling practices
- e) Review of incident response capabilities

9.2 Ongoing Monitoring

- a) Critical vendors must be reassessed annually
 - b) Security ratings services (BitSight, SecurityScorecard) must be used for continuous monitoring
 - c) Vendors must notify the Company of any security incidents within 24 hours
 - d) Vendor access must be reviewed quarterly and removed when no longer needed
-

10. Business Continuity and Disaster Recovery

10.1 Business Continuity Planning

- a) Business Impact Analysis (BIA) must be conducted annually
- b) Business Continuity Plans (BCP) must be developed for all critical business processes
- c) BCPs must be tested at least annually through tabletop exercises or full simulations

- d) Alternate processing sites must be available for critical systems

10.2 Disaster Recovery

- a) Disaster Recovery Plans (DRP) must be documented for all critical systems
 - b) DR failover must be tested semi-annually
 - c) Maximum tolerable downtime for critical systems: 4 hours
 - d) Recovery procedures must be documented step-by-step and accessible during an outage
-

11. Compliance and Enforcement

11.1 Compliance Monitoring

- a) Security audits conducted annually by internal audit and biennially by external auditors
- b) Compliance with this policy monitored through automated tools and manual reviews
- c) Non-compliance findings tracked to remediation with defined timelines
- d) CISO provides quarterly security posture reports to the Board Risk Committee

11.2 Violations

Violations of this policy may result in disciplinary action up to and including termination, and may be subject to legal action. All suspected violations must be reported to the Information Security Team.

11.3 Policy Review

This policy is reviewed semi-annually by the CISO and annually approved by the Board of Directors. Emergency updates may be issued in response to significant threats or regulatory changes.

Appendix A: Acceptable Use Policy - See separate document POL-IS-006-A

Appendix B: Incident Response Plan - See separate document POL-IS-006-B

Appendix C: System Classification Guide - See separate document POL-IS-006-C

Appendix D: Security Exception Request Form - See separate document POL-IS-006-D